

Multi user test

Captured (definition-capture) · 7 October 2026 · Three test accounts, each trying to reach the other two accounts' data

Outcome: 626 of 626 checks passed, 0 failed. No account could read, add to, change, delete or link to another account's data, through the database or through the app, and a signed-out visitor could reach nothing. The live database carries exactly the same protections as the copy that was tested.

What was tested

Whether one signed-in account can reach another account's data. Three accounts, **A**, **B** and **C**, each had its own data in every one of the app's 16 tables, and each tried to get at the other two accounts' data in every way the app and its database offer:

- **Glossary:** words, phrases, verb tables, grammar rules (`items`), collections (`tags` , `item_tags`), sources.
- **Learning:** flashcard decks and cards, progress, reviews, verb practice progress.
- **Account:** settings, plan (free or paid), tutor usage.
- **Tutor:** conversations, saved answers, the rules saved from them, the search log.
- **Database functions** the app calls: saving items, building a deck, recording a review, practising a verb, renaming a collection or source, the dashboard summary, and the tutor search.

Each kind of attempt was made by every account against both of the others (six attacker and victim pairs):

- **Read** the other account's rows, and read whole tables unfiltered.
- **Insert** rows in the other account's name.
- **Change** and **delete** the other account's rows.
- **Link** own data to theirs: own words under their source or collection, their items in own deck, own answers in their conversation, their rules linked to own conversation.
- **Use functions** on their data: review or practise their items, build a deck from their collection, rename their collection or source, overwrite their word by its id, search their tutor answers.
- **Through the app:** open their rules, words, phrases and tutor conversations by id; ask the tutor in their conversation, merge their answers, search their answers.
- **Raise own rights:** upgrade own plan to paid, wipe own message usage or search log to reset the limits, rewrite own saved tutor answers.
- **Signed-out visitor:** read every table, call the functions and the tutor routes, open account pages.

How it was tested

Where	On the local copy of the database (Supabase in Docker) and the app running on this computer against it, not on the live site: the live sign-up has a captcha a script cannot pass, and no test accounts or data were put into production. The local copy is built from exactly the same migrations as the live database.
Same as live	The access rules (row level security), table and column permissions, and function settings of the live database and the local copy were fingerprinted, read-only, and compared: identical , 388 entries each (fingerprint <code>749a5ce3...</code> on both).

Accounts and data	Three accounts were created through the normal sign-up (<code>usera</code> , <code>userb</code> , <code>userc</code> at <code>multiuser.test</code>). Each was given one row in every table: a word, phrase, verb table and rule, a collection and source, a deck with a card, progress, a review, verb practice, settings, a plan, tutor usage, a tutor conversation with two answers, a saved-rule link and a search. Each account's tutor answers contained a word unique to it (<code>ZauberwortA</code> and so on), so a leak in search would show.
Database attacks	A script signed in as each account and used that account's own login token against the public database interface, exactly as a curious or hostile user of the app could, with the same public key the app uses. 562 checks.
App attacks	A real browser (Playwright, Chromium) signed in through the sign-in page as each account, opened the other accounts' pages by their ids, and sent requests to the tutor routes from inside the signed-in page, so the real session cookie was used. 64 checks.
What counted as a pass	A read returned none of the other account's rows; a change or delete affected 0 of their rows; an insert or link was refused for an access reason (permission denied, or a link across accounts refused). A refusal for any other reason, such as a data rule, would have been marked inconclusive, not passed. Finally every account's data was fingerprinted before and after all attempts and had to be unchanged.
Testing the test	Row level security was switched off on one table (<code>tags</code>) in the local copy and the database test rerun: it reported 18 failures (accounts reading and planting each other's collections), proving it catches a real leak. The protection was switched back on and the final run made.
Clean-up	The three test accounts and everything they owned were deleted, and the local database and app stopped. Nothing was changed on the live site.

Outcome

Area	Checks	Passed	Failed
Table access	432	432	0
Cross-account links	27	27	0
Database functions	24	24	0
Own rights	12	12	0
Signed-out visitor	25	25	0
Integrity	49	49	0
App pages	33	33	0
Tutor routes	24	24	0
All	626	626	0

Table access: read, insert, change and delete another account's rows, and read whole tables (every pair of accounts)

Table	Holds	Checks	Outcome
items	words, phrases, verb tables, grammar rules	27	Passed 27/27
tags	collections and rule topics	27	Passed 27/27
item_tags	which items are in which collection	27	Passed 27/27
sources	where words came from	27	Passed 27/27
decks	flashcard decks	27	Passed 27/27
deck_cards	cards in a deck	27	Passed 27/27
progress	flashcard progress	27	Passed 27/27
reviews	every answer given	27	Passed 27/27
verb_tense_progress	verb practice progress	27	Passed 27/27
user_settings	settings	27	Passed 27/27
account_plans	free or paid plan	27	Passed 27/27
tutor_usage	tutor messages used	27	Passed 27/27

Table	Holds	Checks	Outcome
tutor_conversations	tutor conversations	27	Passed 27/27
tutor_exchanges	tutor questions and answers	27	Passed 27/27
tutor_conversation_rules	rules saved from a conversation	27	Passed 27/27
tutor_searches	tutor search log	27	Passed 27/27

Links to another account's data

Target	Attempt	Expected	What happened	Outcome
items	own word filed under the other account's source	refused	23503 insert or update on table "items" violates foreign key constraint "items_source_id_user_id_fkey"	Passed 3/3
item_tags	own item put in the other account's collection	refused	23503 insert or update on table "item_tags" violates foreign key constraint "item_tags_tag_id_context_user_id_"	Passed 3/3
deck_cards	the other account's item put in own deck	refused	23503 insert or update on table "deck_cards" violates foreign key constraint "deck_cards_item_id_user_id_fkey"	Passed 3/3
progress	own progress on the other account's item	refused	23503 insert or update on table "progress" violates foreign key constraint "progress_item_id_user_id_fkey"	Passed 3/3
reviews	own review of the other account's item	refused	23503 insert or update on table "reviews" violates foreign key constraint "reviews_item_id_user_id_fkey"	Passed 3/3
verb_tense_progress	own practice of the other account's verb table	refused	23503 insert or update on table "verb_tense_progress" violates foreign key constraint "verb_tense_progress_ite"	Passed 3/3
tutor_exchanges	own answer added to the other account's conversation	refused	23503 insert or update on table "tutor_exchanges" violates foreign key constraint "tutor_exchanges_conversatio"	Passed 3/3
tutor_conversation_rules	the other account's rule linked from own conversation	refused	23503 insert or update on table "tutor_conversation_rules" violates foreign key constraint "tutor_conversation"	Passed 3/3
tutor_conversation_rules	own rule linked to the other account's tutor answer	refused	23503 insert or update on table "tutor_conversation_rules" violates foreign key constraint "tutor_conversation"	Passed 3/3

Database functions used on another account's data

Target	Attempt	Expected	What happened	Outcome
record_review	record a review on the other account's word	refused or no effect	P0001 not your item	Passed 3/3
record_tense_review	practise the other account's verb table	refused or no effect	P0001 not your verb table	Passed 3/3
build_deck	build a deck from the other account's collection	no foreign cards	deck built, 0 foreign cards	Passed 3/3
rename_tag	rename the other account's collection	no effect	P0001 no such tag	Passed 3/3
rename_item_source	rename the other account's source	no effect	P0001 no such source	Passed 3/3
save_items	overwrite the other account's word by its id	refused or no effect	23505 duplicate key value violates unique constraint "items_pkey"	Passed 3/3
search_tutor	search for the other account's tutor answers	none found	0 found	Passed 3/3
home_summary	dashboard figures include the other account's data	only own data	own figures only	Passed 3/3

Raising one's own rights

Target	Attempt	Expected	What happened	Outcome
account_plans	upgrade own plan to paid	refused	42501 permission denied for table account_plans	Passed 3/3
tutor_usage	delete own usage to reset the message allowance	refused	42501 permission denied for table tutor_usage	Passed 3/3
tutor_searches	delete own search log to reset the hourly search limit	refused	42501 permission denied for table tutor_searches	Passed 3/3
tutor_exchanges	rewrite own saved tutor answers	refused	42501 permission denied for table tutor_exchanges	Passed 3/3

Through the app: pages and tutor routes

Target	Attempt	Expected	What happened	Outcome
/vocabulary	word list shows the other accounts' words	only own words	own word only	Passed 3/3
/grammar	rule list shows the other accounts' rules	only own rules	own rule only	Passed 3/3
/tutor_sidebar	conversation list shows the other accounts' conversations	only own	own conversation only	Passed 3/3
/rule?id=...	open the other account's rule by its id	"Rule not found"	Rule not found	Passed 6/6

Target	Attempt	Expected	What happened	Outcome
/word?id=...	open the other account's word by its id	"Word not found"	Word not found	Passed 6/6
/phrase?id=...	open the other account's phrase by its id	"Phrase not found"	Phrase not found	Passed 6/6
/tutor?c=...	open the other account's tutor conversation	"That conversation was not found."	not found	Passed 6/6
POST /api/tutor	ask a question inside the other account's conversation	404, nothing spent	404 {"error": "not_found"}	Passed 6/6
POST /api/tutor/merge	merge the other account's answers in their conversation	404, nothing spent	404 {"error": "not_found"}	Passed 6/6
POST /api/tutor/merge	merge the other account's answers into own conversation	400, nothing spent	400 {"error": "bad_request"}	Passed 6/6
POST /api/tutor/search	search for words only in the other account's answers	no results from them	200, 0 of their conversations found	Passed 6/6

Signed-out visitor

Target	Attempt	Expected	What happened	Outcome
items	read the table	refused or empty	42501 permission denied for table items	Passed 1/1
tags	read the table	refused or empty	42501 permission denied for table tags	Passed 1/1
item_tags	read the table	refused or empty	42501 permission denied for table item_tags	Passed 1/1
sources	read the table	refused or empty	42501 permission denied for table sources	Passed 1/1
decks	read the table	refused or empty	42501 permission denied for table decks	Passed 1/1
deck_cards	read the table	refused or empty	42501 permission denied for table deck_cards	Passed 1/1
progress	read the table	refused or empty	42501 permission denied for table progress	Passed 1/1
reviews	read the table	refused or empty	42501 permission denied for table reviews	Passed 1/1
verb_tense_progress	read the table	refused or empty	42501 permission denied for table verb_tense_progress	Passed 1/1
user_settings	read the table	refused or empty	42501 permission denied for table user_settings	Passed 1/1
account_plans	read the table	refused or empty	42501 permission denied for table account_plans	Passed 1/1
tutor_usage	read the table	refused or empty	42501 permission denied for table tutor_usage	Passed 1/1

Target	Attempt	Expected	What happened	Outcome
tutor_conversations	read the table	refused or empty	42501 permission denied for table tutor_conversations	Passed 1/1
tutor_exchanges	read the table	refused or empty	42501 permission denied for table tutor_exchanges	Passed 1/1
tutor_conversation_rules	read the table	refused or empty	42501 permission denied for table tutor_conversation_rules	Passed 1/1
tutor_searches	read the table	refused or empty	42501 permission denied for table tutor_searches	Passed 1/1
search_tutor	call the function	refused	42501 permission denied for function search_tutor	Passed 1/1
home_summary	call the function	refused	42501 permission denied for function home_summary	Passed 1/1
save_items	call the function	refused	42501 permission denied for function save_items	Passed 1/1
POST /api/tutor/	call the tutor route	401	401	Passed 1/1
POST /api/tutor/merge/	call the tutor route	401	401	Passed 1/1
POST /api/tutor/search/	call the tutor route	401	401	Passed 1/1
/tutor/	open an account's page	sent to the landing page	landed on /	Passed 1/1
/rule/	open an account's page	sent to the landing page	landed on /	Passed 1/1
/word/	open an account's page	sent to the landing page	landed on /	Passed 1/1

Integrity afterwards

Target	Attempt	Expected	What happened	Outcome
items	account's rows unchanged by the other accounts' attempts	unchanged	unchanged	Passed 3/3
tags	account's rows unchanged by the other accounts' attempts	unchanged	unchanged	Passed 3/3
item_tags	account's rows unchanged by the other accounts' attempts	unchanged	unchanged	Passed 3/3
sources	account's rows unchanged by the other accounts' attempts	unchanged	unchanged	Passed 3/3

Target	Attempt	Expected	What happened	Outcome
decks	account's rows unchanged by the other accounts' attempts	unchanged	changed only by the account itself (its own deck)	Passed 3/3
deck_cards	account's rows unchanged by the other accounts' attempts	unchanged	unchanged	Passed 3/3
progress	account's rows unchanged by the other accounts' attempts	unchanged	unchanged	Passed 3/3
reviews	account's rows unchanged by the other accounts' attempts	unchanged	unchanged	Passed 3/3
verb_tense_progress	account's rows unchanged by the other accounts' attempts	unchanged	unchanged	Passed 3/3
user_settings	account's rows unchanged by the other accounts' attempts	unchanged	unchanged	Passed 3/3
account_plans	account's rows unchanged by the other accounts' attempts	unchanged	unchanged	Passed 3/3
tutor_usage	account's rows unchanged by the other accounts' attempts	unchanged	unchanged	Passed 3/3
tutor_conversations	account's rows unchanged by the other accounts' attempts	unchanged	unchanged	Passed 3/3
tutor_exchanges	account's rows unchanged by the other accounts' attempts	unchanged	unchanged	Passed 3/3
tutor_conversation_rules	account's rows unchanged by the other accounts' attempts	unchanged	unchanged	Passed 3/3
tutor_searches	account's rows unchanged by the other accounts' attempts	unchanged	unchanged	Passed 3/3
tutor_usage	messages spent by the refused tutor attempts	none	before, after	Passed 1/1

Recommendations

No leak was found, so nothing needs repairing. To keep it that way:

- **Rerun this test after any change to the database:** a new table, a changed rule or a new function. A new table without row level security would be the most likely way for a leak to appear; the project rule in CLAUDE.md requires it, and this test would catch a slip. The two test scripts can be added to the repository (beside `supabase/tests/`) so the next model can

run them; say if you want that.

- **Keep the live and local copies in step.** The fingerprint comparison here is the cheap way to confirm a result on the local copy holds for the live site; rerun it after each `db push`.
- **Accepted limits, not leaks** (from the security scan, unchanged here): an account can call the tutor search function directly, bypassing its own hourly search count but reading only its own data and spending no model money; and it can reorder its own sidebar or link its own rule to its own answer in another conversation. Each affects only the account itself.
- **Still for you to check in the dashboards**, as these were outside this test: Supabase Authentication settings (captcha on, email confirmation, rate limits), and Vercel's Sensitive setting on the two secrets and its Deployment Protection mode.